

Chapter 1 — Authority, Scope, and Security-Privacy-Trust Program Governance

1. Document control

- Identifier: HAL-BVI-01
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Establish the living program, authority hierarchy, accountable roles, control ownership, risk treatment, exceptions, and the non-transfer of constitutional authority.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Articles I-XIV; Decisions 1, 5, 26, 27, 47, 48, 58
- Book II: Chapters 1, 3-5, 35
- Book III: Chapters 1, 5, 8-9
- Book IV: CMP-01, CMP-03, CMP-17-21, CMP-24
- Book X: Chapters 1, 3-4, 7-8, 10
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Owner, Security and Trust Executive, Control Owner, Risk Steward, Independent Assessor, Evidence Custodian.

6. Normative controls

VI-GOV-01-001 — Apply the canon hierarchy

Every program decision MUST preserve Book I, implement Book II, follow Book III, respect Book IV ownership, and use Book X semantics; conflict MUST halt the affected decision and be recorded.

- Applicability: all program decisions
- Responsible role: Security and Trust Executive
- Enforcement: source-version gate and conflict workflow
- Required evidence: source manifest and decision record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-GOV-01-002 — Separate protection from restraint

Every risk assessment and control design MUST state whether it protects HAL, prevents HAL from exceeding Authority, or does both; neither objective MAY be omitted when applicable.

- Applicability: all controls and risks
- Responsible role: Control Owner
- Enforcement: control-schema validation
- Required evidence: control record with protection objective
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-GOV-01-003 — Assign control accountability

Each active control MUST have one accountable Control Owner, identified operators, an assessor, evidence, test frequency, failure response, and succession coverage.

- Applicability: all controls
- Responsible role: Security and Trust Executive
- Enforcement: catalog completeness gate
- Required evidence: approved control assignment
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

VI-GOV-01-004 — Classify risk by consequence

Risks MUST be classified using the highest material consequence across authority, constitutional invariant, privacy, trust boundary, compromise, continuity, safety, irreversibility, and blast radius.

- Applicability: all risks
- Responsible role: Risk Steward
- Enforcement: risk-register validation and review
- Required evidence: risk assessment
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-GOV-01-005 — Maintain separation of duties

No person or service MAY solely request, approve, execute, and attest a protected security, privacy, trust, key, Treaty, or break-glass change.

- Applicability: protected changes
- Responsible role: Control Owner
- Enforcement: role-conflict policy
- Required evidence: approval and execution evidence
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-GOV-01-006 — Operate a control lifecycle

Controls **MUST** be proposed, reviewed, approved, implemented, tested, monitored, remediated, and retired through versioned records with preserved history.

- Applicability: all controls
- Responsible role: Control Owner
- Enforcement: control-state machine
- Required evidence: control lifecycle record
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

VI-GOV-01-007 — Time-bound all exceptions

An exception **MUST** identify control, scope, rationale, risk, compensating controls, approver, evidence, effective date, review date, expiry, and revocation triggers; silent or permanent exceptions are prohibited.

- Applicability: all exceptions
- Responsible role: Risk Steward
- Enforcement: exception registry and expiry enforcement
- Required evidence: signed exception record
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-GOV-01-008 — Forbid program-created authority

Security status, trust, identity, credentials, certificates, risk acceptance, or control compliance **MUST NOT** create Permission, Authority, Owner approval, capability-class approval, or Treaty scope.

- Applicability: all program actions
- Responsible role: Security and Trust Executive
- Enforcement: negative authority-path tests
- Required evidence: authority non-creation attestation
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Articles I-XIV; Decisions 1, 5, 26, 27, 47, 48, 58
- Book II: Chapters 1, 3-5, 35
- Book III: Chapters 1, 5, 8-9
- Book IV: CMP-01, CMP-03, CMP-17-21, CMP-24
- Book X: Chapters 1, 3-4, 7-8, 10

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a credential with favorable Trust evidence, passing scan, active certificate, or urgent incident as Permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.